# 애플리케이션 보안 운영

KOREA
코리아IT아카데미학원

| class | 정보보안 산업기사 취득과정 A |
|---|---|
| name | 조채언 |

# 목 차


Ⅰ. 애플리케이션 구조 및 보안 솔루션 현황 ····· 3

가. 정보보호 관련 법률과 해당 기관의 관련 규정 및 지침 ····· 3

나. 개인정보보호 관련 법규 및 준거 사항 ····· 4

다. 애플리케이션 구조 및 보안 솔루션 현황 토폴로지 ····· 5

라. 자산관리대장 ····· 10

Ⅱ. 보안솔루션 구축 및 운영 방안 ····· 11

가. Security Onion 구축 및 운영 방안 ····· 11

나. 애플리케이션 공격 유형 분석 및 예방조치 ····· 12

Ⅲ. 웹 서버 취약점 점검 체크리스트 ····· 13

Ⅳ. 모의 해킹 및 취약점 점검 체크리스트 ····· 14

가. 메일서버 / DNS서버 / 라우터 체크리스트 ····· 14

나. 체크리스트 기반 DNS 구현 ····· 15

다. 운영 체계 명령 실행 보안 취약점 확인 ····· 18

다. 운영 체계 명령 실행 보안 대응 방안 ····· 21

Ⅴ. 애플리케이션 보안 솔루션 개선 방안 점검 ····· 22

가. 애플리케이션 현항에 따라 점검 체크리스트 ····· 22

나. 악의적인 공격 위험 파악 방법 ····· 22

다. 보안관련 법 및 규정에 따른 준거 사항 ····· 23

Ⅵ. 애플리케이션 보안 솔루션 운영 ····· 24

가. 운영 중인 애플리케이션 보안 솔루션 점검체크리스트 ····· 24

나. 점검 및 결과 값 ····· 25

다. 점검 항목 이상 상황 발견 시 중요도별 조치 방법 ····· 26

Ⅶ. 애플리케이션 보안 솔루션 업데이트 적용 ····· 27

# Ⅰ. 애플리케이션 구조 및 보안 솔루션 현황

## 가. 정보보호 관련 법률과 해당 기관의 관련 규정 및 지침

### 1. 정보보호 관련 법률

- **정보통신망법 :** 정보통신망을 안전하게 이용할 수 있도록 하고, 정보통신망에서 발생하는 해킹, 악성코드 유포, 개인정보 침해 등의 문제를 예방하기 위해 제정된 법률이다. 정보통신서비스 제공자의 보안 의무와 이용자 보호에 관한 내용을 담고 있다.
- **전자서명법 :** 전자문서에 사용되는 전자서명의 법적 효력을 인정하고, 전자거래가 안전하고 신뢰성 있게 이루어질 수 있도록 하기 위한 법률이다. 전자서명을 통해 본인 확인과 문서의 위·변조 여부를 확인할 수 있도록 규정하고 있다.
- **정보보호산업진흥법 :** 정보보호 산업을 국가 차원에서 육성하고 지원하기 위해 제정된 법률이다. 정보보호 기술 개발, 전문인력 양성, 관련 기업 지원 등을 통해 정보보호 산업의 경쟁력을 강화하는 것을 목적으로 한다.
- **개인정보 보호법 :** 개인정보를 수집·이용·제공하는 과정에서 국민의 개인정보를 보호하고 권리를 보장하기 위한 기본 법률이다. 개인정보 처리 원칙, 정보주체의 권리, 개인정보처리자의 의무, 개인정보 유출 시 조치 사항 등을 규정하고 있다.

### 2. 해당 기관의 관련 규정 및 지침

- **개인정보의 안전성 확보조치 기준 :** 개인정보 보호를 위한 관리적·기술적·물리적 보호조치 기준 제시한다.
- **개인정보 처리방침 작성지침 :** 개인정보 처리방침 작성 및 공개 방법을 규정한다.
- **정보보호 및 개인정보보호 관리체계(ISMS-P) 인증기준 :** 정보보호 및 개인정보보호 관리체계 구축·운영 기준 제시한다.
- **국가 정보보안 기본지침 :** 국가기관 및 공공기관의 정보보안 관리 기준을 규정하고, 정보시스템 접근통제, 계정관리, 사고대응 등을 포함한다.

## 나. 개인정보보호 관련 법규 및 준거 사항

- **개인정보 보호법 제24조 (고유 식별 정보의 처리제한) 3항**
  고유 식별 정보(주민 등록 번호, 여권 번호, 운전면허 번호, 외국인 등록 번호)를 처리하는 경우 그 정보가 분실, 도난, 유출, 변조 또는 훼손되지 않도록 암호화 등 안정성 확보에 필요한 조치를 해야 한다.
- **개인정보 보호법 제29조 (안전 조치 의무화)**
  개인 정보가 분실, 도난, 유출, 변조 또는 훼손되지 않도록 내부관리 계획 수립, 접속 기록 보관 등 안전성 확보에 필요한 기술적, 관리적, 물리적 조치를 해야 한다.
- **개인정보 보호법 시행령 제30조(개인 정보의 안정성 확보 조치) 1항, 3항**
  개인 정보를 안전하게 저장, 전송할 수 있는 암호화 기술의 적용 또는 이에 상응하는 조치를 해야 한다.
- **개인정보 보호법 시행령 제48조의2(개인정보의 안전성 확보 조치에 관한 특례)**
  개인 정보가 안전하게 저장, 전송될 수 있도록 다음과 같은 보안 조치를 해야 한다.
  · 비밀번호 및 바이오 정보(지문, 홍채, 음성, 필적 등) 일방향 암호화 저장
  · 주민 등록 번호 및 계좌 번호 등 금융 정보의 암호화 저장
  · 개인 정보 및 인증 정보를 송·수신하는 경우 보안
  · 서버 구축 등의 조치
  · 그 밖의 암호화 기술을 이용한 보안 조치

## 다. 애플리케이션 구조 및 보안 솔루션 현황 토폴로지

### 1. 애플리케이션 구조

#### (1) 실행 중인 프로세스 확인

```
root@roror:/home/roror# ps -ef | grep ssh
root        1497       1  0 00:54 ?        00:00:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10
-100 startups
roror       2413    2267  0 00:54 ?        00:00:00 /usr/libexec/gcr-ssh-agent --base-dir /run
/user/1000/gcr
root        4474    3940  0 01:47 pts/1    00:00:00 grep --color=auto ssh
root@roror:/home/roror# ps -ef | grep mysql
mysql       1811       1  0 00:54 ?        00:00:01 /usr/sbin/mariadbd
root        4476    3940  0 01:48 pts/1    00:00:00 grep --color=auto mysql
root@roror:/home/roror# ps -ef | grep ftp
root        4478    3940  0 01:48 pts/1    00:00:00 grep --color=auto ftp
root@roror:/home/roror# ps -ef | grep tomcat
root        4480    3940  0 01:48 pts/1    00:00:00 grep --color=auto tomcat
root@roror:/home/roror# ps -ef | grep apache
root        1628       1  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1649    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1782    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1783    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1786    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1789    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
www-data    1790    1628  0 00:54 ?        00:00:00 /usr/sbin/apache2 -k start
root        4482    3940  0 01:49 pts/1    00:00:00 grep --color=auto apache
```

- **ps -ef | grep ssh**
  sshd가 실행 중인 것을 확인하였다. 이는 SSH 원격 접속이 가능하고, 관리자 원격 관리용 서비스 운영 중이라는 의미이다.
- **ps -ef | grep mysql**
  MariaDB 프로세스가 실행 중임을 확인하였다. 이는 데이터 저장 기능 수행과 웹 애플리케이션과 연동이 가능하다는 의미이다.
- **ps -ef | grep ftp**
  vsftpd 관련 프로세스가 확인되지 않았다. 이는 FTP 서비스가 미운영 중이고 파일 전송 서비스가 비활성화된 상태이다.
- **ps -ef | grep tomcat**
  Apache Tomcat 서비스가 실행되지 않았다. JAVA 기반 웹 애플리케이션 서버를 사용하고 있지 않다.
- **ps -ef | grep apache**
  Apache HTTP Server 서비스가 다중 프로세스로 실행 중임을 확인하였다. 이는 HTTP/HTTPS 웹 서비스 운영 중이고, 클라이언트 요청 처리 가능한 상태이다.

**(2) 포트 상태 확인**

```
root@ororor:/home/ororor# netstat -antp
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program na
me
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      1/init

tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      1811/mariadbd

tcp        0      0 127.0.0.1:631           0.0.0.0:*               LISTEN      1651/cupsd

tcp6       0      0 :::443                  :::*                    LISTEN      1628/apache2

tcp6       0      0 :::80                   :::*                    LISTEN      1628/apache2

tcp6       0      0 :::22                   :::*                    LISTEN      1/init

tcp6       0      0 ::1:631                 :::*                    LISTEN      1651/cupsd
```

**netstat--antp**

외부 접속 가능 서비스 식별과 내부/외부 통신 포트를 확인한다.

**확인된 포트 :**

22 - OpenSSH

3306 – MariaDB

80 - Apache HTTP Server

443 - Apache HTTP Server

631 – CUPS

### (3) 네트워크 인터페이스 확인

```
root@roror:/home/roror# ifconfig
br0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.0.0.222  netmask 255.255.255.0  broadcast 10.0.0.255
        inet6 fe80::a877:fff:feaf:7112  prefixlen 64  scopeid 0x20<link>
        ether aa:77:0f:af:71:12  txqueuelen 1000  (Ethernet)
        RX packets 66663  bytes 99737385 (99.7 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 10365  bytes 593999 (593.9 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

ens33: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        ether 00:0c:29:1b:71:c5  txqueuelen 1000  (Ethernet)
        RX packets 66666  bytes 100670868 (100.6 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 10373  bytes 656207 (656.2 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

ens36: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        ether 00:0c:29:1b:71:cf  txqueuelen 1000  (Ethernet)
        RX packets 0  bytes 0 (0.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 105  bytes 10666 (10.6 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 55  bytes 5316 (5.3 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 55  bytes 5316 (5.3 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

**ifconfig**
서버의 네트워크 구성을 확인할 수 있다.

**주요 IP :** 10.0.0.222

**인터페이스 :**
- br0
- ens33
- ens36
- lo

**(4) 방화벽 정책 확인**

```
root@roror:/home/roror# iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere             state RELATED,ESTABLISHED
ACCEPT     icmp --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp dpt:ssh
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp dpt:http
ACCEPT     tcp  --  anywhere             anywhere             state NEW tcp dpt:https
```

**iptables -L**

기본 차단 정책을 적용하고 있고 허용된 서비스만 접근이 가능하며 IDS/IPS 연동이 가능한 구조이다.

**허용 포트 :**

- SSH (22)
- HTTP (80)
- HTTPS (443)

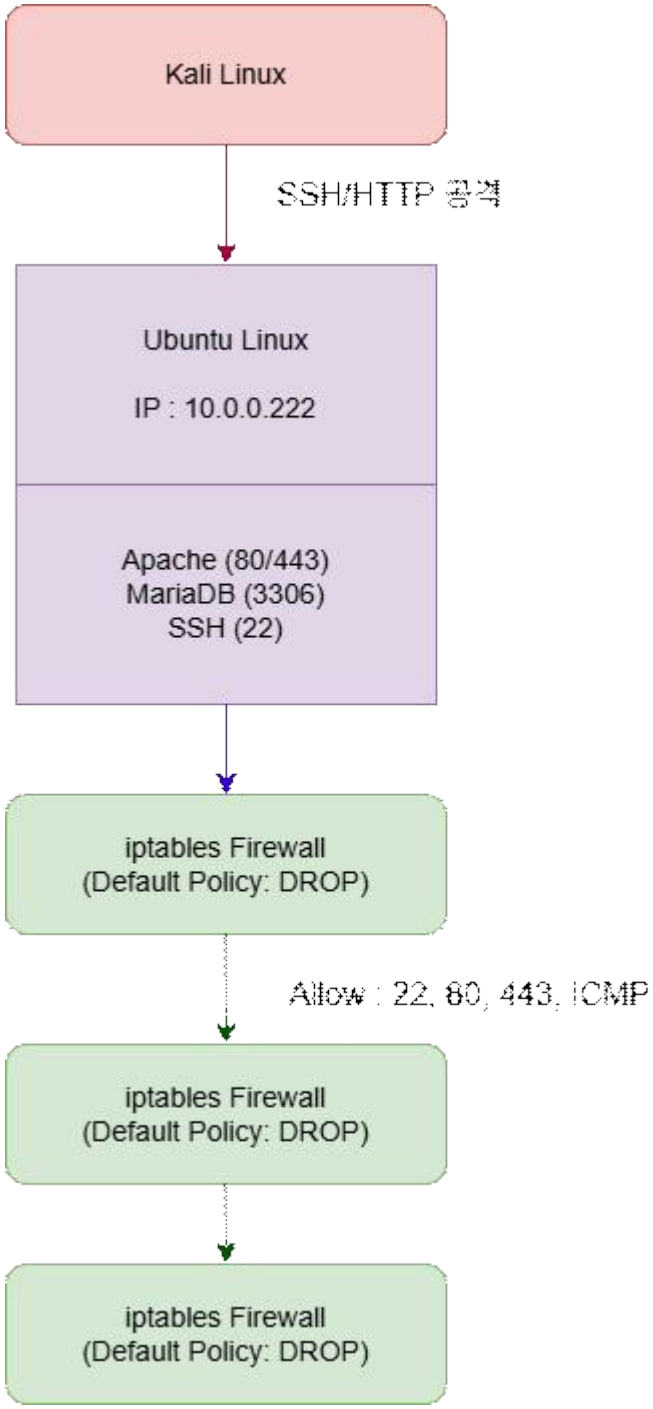
**(5) 인증 로그 확인**

```
root@roror:/home/roror# tail -f /var/log/auth.log
2026-06-22T01:25:01.492481+00:00 roror CRON[3912]: pam_unix(cron:session): session opened fo
user root(uid=0) by root(uid=0)
2026-06-22T01:25:01.494913+00:00 roror CRON[3912]: pam_unix(cron:session): session closed fo
user root
2026-06-22T01:30:17.068569+00:00 roror sudo:    roror : TTY=pts/0 ; PWD=/home/roror ; USER=r
t ; COMMAND=/bin/bash
2026-06-22T01:30:17.069609+00:00 roror sudo: pam_unix(sudo:session): session opened for user
oot(uid=0) by roror(uid=1000)
2026-06-22T01:35:01.510103+00:00 roror CRON[3975]: pam_unix(cron:session): session opened fo
user root(uid=0) by root(uid=0)
2026-06-22T01:35:01.513217+00:00 roror CRON[3975]: pam_unix(cron:session): session closed fo
user root
2026-06-22T01:39:01.526822+00:00 roror CRON[3980]: pam_unix(cron:session): session opened fo
user root(uid=0) by root(uid=0)
2026-06-22T01:39:01.529224+00:00 roror CRON[3980]: pam_unix(cron:session): session closed fo
user root
2026-06-22T01:45:01.536241+00:00 roror CRON[4463]: pam_unix(cron:session): session opened fo
user root(uid=0) by root(uid=0)
2026-06-22T01:45:01.546361+00:00 roror CRON[4463]: pam_unix(cron:session): session closed fo
user root
```

**tail /var/log/auth.log**

rsyslog 로그에 CRON 작업 기록이 정상 저장되었고, 시스템 감사 및 추적이 가능하다.

## 2. 토폴로지


Kali Linux
SSH/HTTP 공격
Ubuntu Linux
IP : 10.0.0.222
Apache (80/443)
MariaDB (3306)
SSH (22)
iptables Firewall
(Default Policy: DROP)
Allow : 22, 80, 443, ICMP
iptables Firewall
(Default Policy: DROP)
iptables Firewall
(Default Policy: DROP)

## 라. 자산관리대장

| 자산 정보 | | | | | | | 자산 가치 (중요도) | | | | 비고 |
|---|---|---|---|---|---|---|---|---|---|---|---|
| 자산 코드 | 자산 유형 | 자산명 | 제조사/모델 | 위치 /도입일 | 담당자 | 관리부서 | C | I | A | 등급 | |
| HW01 | 하드웨어 | Ubuntu 서버 운영 장비 | 토폴로지 기반 / 가상머신(VM) | 전산실 / 260622 | roror | 보안운영팀 | 상 | 상 | 상 | 상 | |
| OS01 | 소프트웨어 | OS (Ubuntu Server) | Canonical / Ubuntu | 가상머신 / 260622 | roror | 보안운영팀 | 상 | 상 | 상 | 상 | |
| WB01 | 서비스 | 웹 서비스 (Apache) | Apache / HTTP, HTTPS | Ubuntu OS / 260622 | roror | 보안운영팀 | 중 | 상 | 상 | 상 | |
| DB01 | 데이터베이스 | 업무 데이터베이스 (MariaDB) | MariaDB / SQL | Ubuntu OS / 260622 | roror | 보안운영팀 | 상 | 상 | 중 | 상 | |
| SW01 | 소프트웨어 | 원격 제어 서비스 (SSH) | OpenSSH / SSH | Ubuntu OS / 260622 | roror | 보안운영팀 | 상 | 상 | 중 | 상 | |
| SW02 | 소프트웨어 | 프린터 서버 서비스 (CUPS) | OpenPrinting / CUPS | Ubuntu OS / 260622 | roror | 보안운영팀 | 하 | 중 | 하 | 중 | |
| SE01 | 보안솔루션 | 방화벽 (iptables) | Linux / Netfilter | Ubuntu OS / 260622 | roror | 보안운영팀 | 상 | 상 | 상 | 상 | |
| SE02 | 보안솔루션 | 침입탐지/차단시스템 (IDS/IPS) | 오픈소스 / Snort | Ubuntu OS / 260622 | roror | 보안운영팀 | 중 | 상 | 상 | 상 | |

# Ⅱ. 보안솔루션 구축 및 운영 방안

## 가. Security Onion 구축 및 운영 방안

### 1. 구축 방안

Security Onion은 네트워크 기반 보안 모니터링 플랫폼으로, 침입 탐지(IDS), 로그 수집, 패킷 분석 기능을 통합 제공한다.

Security Onion이 네트워크 트래픽을 실시간으로 분석할 수 있도록 SPAN(Switch Port Analyzer) 포트 또는 Network TAP을 구성해야 한다.

- **인터페이스 분리:** 시스템 관리 및 웹 대시보드 접속을 위한 Management 인터페이스와, 트래픽을 순수하게 수집·분석하기 위해 IP를 할당하지 않는 프로미스큐어스(Promiscuous) 모드의 Sniffing 인터페이스를 물리적 논리적으로 분리하여 구축한다.
- **네트워크 위치:** 외부 방화벽 직후 및 내부 핵심 스위치 백본에 수집 센서를 배치하여 내부망과 외부망 트래픽을 모두 수집한다.

### 2. 운영 방안

Security Onion에 내장된 IDS 엔진(Suricata 등)의 오탐을 줄이고 최신 위협을 탐지하기 위한 지속적인 관리가 필요하다.

**(1) 실시간 트래픽 감시**

- 네트워크 패킷 지속 수집
- 이상 행위 탐지

**(2) 공격 탐지 룰 업데이트**

- 최신 공격 시그니처 반영
- 신규 취약점 대응
- 예 : OWASP Top 10 룰 적용

**(3) 로그 기반 침해사고 분석**

- 인증 로그 분석
- 웹 로그 분석
- 시스템 로그 분석

## 나. 애플리케이션 공격 유형 분석 및 예방조치

**1. SQL Injection**

- **취약점 분석:** SQL 인젝션은 사용자가 입력한 값을 제대로 검사하지 않을 때 발생하는 공격이다. 공격자는 로그인 창이나 URL에 ' OR '1'='1 같은 코드를 넣어서 데이터베이스 명령어를 조작할 수 있다. 이를 통해 정상적인 인증 절차를 우회하거나 데이터베이스 안에 있는 중요한 정보를 조회, 수정, 삭제할 수 있다. 이 공격은 웹사이트에서 가장 많이 발생하는 대표적인 취약점 중 하나이다.
- **솔루션 연동 및 예방조치:** 개발 단계에서는 Prepared Statement를 사용하여 사용자의 입력값이 SQL 문장의 구조를 바꾸지 못하게 해야 한다. 또한 입력값 검증을 통해 특수문자나 비정상적인 명령어를 제한해야 한다. 보안솔루션 측면에서는 Security Onion과 Suricata를 이용하여 SELECT, UNION, DROP, OR 1=1 등의 공격 패턴을 탐지하고 차단할 수 있다.

**2. XSS (Cross-Site Scripting)**

- **취약점 분석:** XSS는 사용자가 입력한 내용이 검증 없이 웹페이지에 그대로 출력될 때 발생하는 공격이다. 공격자는 게시판이나 댓글창에 <script>와 같은 악성 스크립트를 삽입하여 다른 사용자의 브라우저에서 실행되도록 만들 수 있다. 이로 인해 사용자의 쿠키 정보가 탈취되거나 악성 사이트로 이동될 수 있으며, 계정 탈취로 이어질 수 있다.
- **솔루션 연동 및 예방조치:** 개발 단계에서는 입력값과 출력값에 HTML 엔티티 인코딩을 적용하여 브라우저가 스크립트를 실행하지 못하도록 해야 한다. 또한 쿠키에 HttpOnly 옵션을 설정하여 스크립트를 통한 접근을 막을 수 있다. 보안솔루션 측면에서는 Security Onion과 WAF를 통해 <script>, javascript:, onerror 같은 악성 코드 패턴을 탐지하고 공격자의 IP를 차단할 수 있다.

**3. CSRF (Cross-Site Request Forgery)**

- **취약점 분석:** CSRF는 사용자가 로그인된 상태를 이용해 공격자가 원하지 않는 요청을 강제로 보내게 만드는 공격이다. 예를 들어 사용자가 로그인한 상태에서 공격자가 만든 링크를 클릭하면 비밀번호 변경, 회원 탈퇴, 송금 같은 작업이 본인 의사와 상관없이 실행될 수 있다. 이 공격은 사용자의 세션 정보를 악용하기 때문에 매우 위험하다.
- **솔루션 연동 및 예방조치:** 솔루션 연동 및 예방조치: 개발 단계에서는 CSRF Token을 사용하여 정상 사용자의 요청인지 확인해야 한다. 또한 중요한 작업을 할 때 비밀번호를 다시 입력하게 하거나 CAPTCHA 인증을 추가할 수 있다. 보안솔루션 측면에서는 Security Onion과 WAF를 통해 HTTP 요청의 Referer와 Origin 값을 확인하여 정상 도메인에서 온 요청인지 검사하고, 비정상적인 요청은 차단할 수 있다.

# Ⅲ. 웹 서버 취약점 점검 체크리스트

| 구분 | | 점검 항목 | O/X |
|---|---|---|---|
| 호스트 OS 보안 점검 | | 1. OS에 대한 최신 패치를 적용하였는가? | |
| | | 2. OS 취약점 점검을 실시하였는가? | |
| | | 3. 웹 서버 전용 호스트로 구성하였는가? | |
| | | 4. 서버에 대한 접근 제어 설정을 하였는가? | |
| | | 5. 관리자 계정은 8자 이상(특수 문자 포함) 패스워드를 사용하는가? | |
| | | 6. 파일 접근 권한을 설정하였는가? | |
| 웹 서버 설치 보안 점검 | | 1. 소스 코드 형태의 배포본으로 설치하였는가? | |
| | | 2. 설치 시 네트워크 접속을 차단하였는가? | |
| | | 3. 로그 파일 보호 설정을 하였는가? | |
| | | 4. 웹 서버에 대한 불필요한 정보 노출을 방지하였는가? | |
| | | 5. 설정 파일을 백업하였는가? | |
| | | 6. SSL/TLS를 사용하였는가? | |
| 네트워크 취약점 점검 | | 1. 네트워크 장비의 원격 접근 제한을 설정하였는가? | |
| | | 2. SNMP 기능을 사용하였는가? | |
| | | 3. 네트워크 장비의 디폴트 아이디, 비밀번호를 변경하였는가? | |
| | | 4. 설정을 통하여 장비의 로그인 시간을 제한하였는가? | |
| | | 5. 네트워크 장비의 로그를 관리하고 있는가? | |
| DB 취약점 점검 | | 1. 사용 중인 DBMS의 최신 패치를 적용하였는가? | |
| | | 2. 디폴트 관리자 아이디를 변경하였는가? | |
| | | 3. 모든 DBMS 계정에 대하여 비밀번호를 설정하였는가? | |
| | | 4. 데이터베이스 내의 사용자별 접속 및 권한 설정을 하였는가? | |
| 웹 애플리케이션 보안 점검 | SQL Injection | 1. 로그인 폼에 대하여 점검하였는가? | |
| | | 2. 게시판 글 조회란에 대하여 점검하였는가? | |
| | | 3. 게시판 URL 로직에 대하여 점검하였는가? | |
| | XSS | 1. 게시판 입력란(제목, 작성자, 전자 우편 주소, 글 입력란)에 대하여 점검하였는가? | |
| | | 2. 홈페이지 조회란에 대하여 점검하였는가? | |
| | | 3. 홈페이지 URL 조작에 대하여 점검하였는가? | |
| | 파일 업로드 | 1. 게시판에 업로드 되는 파일의 확장자를 체크하는가? | |
| | | 2. 변경된 첨부파일의 확장자를 인식할 수 있는가? | |
| | 쿠키 변조 | 1. 쿠키 내의 아이디 값을 변경 시 인식할 수 있는가? | |
| | | 2. 쿠키 내의 코드 값 변경 시 인식할 수 있는가? | |
| | 다운로드 취약점 | 1. 다운로드 URL에 대한 유효성 여부를 체크하였는가? | |
| | | 2. 웹 서버에서 다운로드 가능한 확장자를 관리하는가? | |
| | | 3. 디렉터리 리스팅이 발생하지 않도록 설정하였는가? | |

# Ⅳ. 모의 해킹 및 취약점 점검 체크리스트

## 가. 메일서버 / DNS서버 / 라우터 체크리스트

| 구분 | 체크리스트 항목 | 점검결과 |
|---|---|---|
| 메일 서버 | 한 번에 발송 가능한 참조 발송자 제한 설정 여부 | |
| | 메일 중계 기능 제한 설정 여부 | |
| | 버전 정보 공개 제한 여부 | |
| DNS 서버 | Recursion 기능 제한 여부 | |
| | Zone-transfer 제안 여부 | |
| | 버전 정보 공개 제한 여부 | |
| 라우터 | 불필요한 프로토콜 및 서비스 제거 여부(ICMP 등) | |
| | IP 주소 위조 방지 수단 사용 | |

## 나. 체크리스트 기반 DNS 구현

### 1. Recursion 기능 제한 여부 점검 및 구현

/etc/named.conf

```
recursion yes;
allow-recursion { 10.0.0.0/24; };
dnssec-validation yes;
```

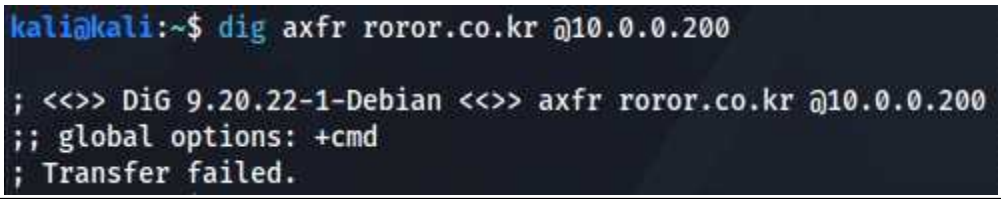
```
kali@kali:~$ dig google.com @10.0.0.200

; <<>> DiG 9.20.22-1-Debian <<>> google.com @10.0.0.200
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 11995
;; flags: qr rd ra; QUERY: 1, ANSWER: 6, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 10ab7e6e66ba6763010000006a420e8953593b4253a4b533 (good)
;; QUESTION SECTION:
;google.com.                    IN      A

;; ANSWER SECTION:
google.com.             300     IN      A       142.251.24.139
google.com.             300     IN      A       142.251.24.100
google.com.             300     IN      A       142.251.24.113
google.com.             300     IN      A       142.251.24.102
google.com.             300     IN      A       142.251.24.138
google.com.             300     IN      A       142.251.24.101

;; Query time: 224 msec
;; SERVER: 10.0.0.200#53(10.0.0.200) (UDP)
;; WHEN: Mon Jun 29 15:19:53 KST 2026
;; MSG SIZE  rcvd: 163
```

/etc/named.conf 파일에서 recursion yes; 와 allow-recursion { 10.0.0.0/24; }; 설정을 통해 내부 네트워크 대역에 대해서만 재귀 질의를 허용하도록 구성하였다. 이후 dig google.com @10.0.0.200 명령어를 통해 외부 도메인 조회가 정상적으로 수행되는 것을 확인하였다. 이를 통해 허가된 내부 사용자만 Recursive Query를 사용할 수 있도록 제한하여 DNS 증폭 공격 및 불필요한 외부 질의 남용을 방지할 수 있다.

**2. Zone-transfer 제한 여부 점검 및 구현**

/etc/named.rfc1912.zones

```
zone "roror.co.kr" IN {
        type primary;
        file "roror.co.kr.zone";
        allow-update { none; };
        allow-transfer { none; };
};
```




/etc/named.rfc1912.zones 파일에서 allow-transfer { none; }; 옵션을 설정하여 모든 외부 Zone Transfer 요청을 차단하였다. 이후 dig axfr roror.co.kr @10.0.0.200 명령어를 실행한 결과 Transfer failed가 출력되어 Zone Transfer가 정상적으로 차단되는 것을 확인하였다. 이를 통해 도메인 내부 레코드 정보 유출을 방지할 수 있다.

### 3. DNS 버전 정보 공개 제한 여부 점검 및 구현

/etc/named.conf

```
recursion yes;
allow-recursion { 10.0.0.0/24; };
version "unknown";
```

```
kali@kali:~$ dig chaos txt version.bind @10.0.0.200

; <<>> DiG 9.20.22-1-Debian <<>> chaos txt version.bind @10.0.0.200
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 12833
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 3058c3a4ceea8c99010000006a421028ca15d7e55e709812 (good)
;; QUESTION SECTION:
;version.bind.                  CH      TXT

;; ANSWER SECTION:
version.bind.           0       CH      TXT     "unknown"

;; Query time: 0 msec
;; SERVER: 10.0.0.200#53(10.0.0.200) (UDP)
;; WHEN: Mon Jun 29 15:26:48 KST 2026
;; MSG SIZE  rcvd: 89
```

/etc/named.conf 파일에서 version "unknown"; 설정을 적용하여 BIND 버전 정보가 외부에 노출되지 않도록 구성하였다. 이후 dig chaos txt version.bind @10.0.0.200 명령어를 통해 질의한 결과 실제 버전 정보 대신 "unknown" 값이 출력되는 것을 확인하였다. 이를 통해 공격자가 DNS 서버 버전을 기반으로 취약점을 식별하는 것을 어렵게 만들어 보안성을 향상시킬 수 있다.

## 다. 운영 체계 명령 실행 보안 취약점 확인

### 1. 보안 레벨 - Low

입력값에 대한 검증이 거의 이루어지지 않아 ping -c 4; cat /etc/passwd 와 같이 세미콜론(;)을 이용하여 추가 명령을 쉽게 실행할 수 있었다. 그 결과 /etc/passwd 파일 내용이 그대로 출력되었으며, 이는 공격자가 시스템 내부 정보에 접근할 수 있음을 보여준다. 즉, Low 단계는 사용자 입력을 그대로 시스템 명령에 전달하기 때문에 가장 취약한 상태라고 볼 수 있다.

**2. 보안 레벨 - Medium**

일부 특수문자에 대한 필터링이 적용되어 보안이 강화되었으나, 완전한 차단은 이루어지지 않았다. 예를 들어 특정 구분자는 제한되었지만 다른 명령 연결 연산자를 이용하여 우회가 가능하였다. 실습 결과 Medium 단계에서도 /etc/passwd 파일을 출력하는 데 성공하였으며, 이는 블랙리스트 방식의 한계점을 보여준다. 차단하지 않은 명령어 조합이 존재할 경우 여전히 공격이 가능하다.

### 3. 보안 레벨 - High

Low와 Medium 단계보다 더 많은 특수문자를 필터링하여 보안 수준이 높아졌지만, 필터링 로직의 허점을 이용해 우회 공격이 가능하였다. 예를 들어 파이프(|) 뒤 공백만 차단하도록 설정된 경우, 공백 없이 바로 명령어를 입력하면 필터를 우회할 수 있었다. 실습에서도 |cat /etc/passwd와 같은 방식으로 시스템 파일을 조회하는 데 성공하였으며, 이는 단순 문자열 차단 방식만으로는 완전한 보안을 보장할 수 없음을 의미한다.

## 다. 운영 체계 명령 실행 보안 대응 방안

1. 사용자 입력값에 대한 화이트리스트(Whitelist) 기반 검증이 필요하다. Command Injection은 입력값에 특수문자나 추가 명령을 삽입하여 발생하는 취약점이므로, 허용된 값만 입력받도록 제한하는 것이 가장 효과적이다. 예를 들어 IP 주소를 입력받는 경우 숫자와 점(.)만 허용하고, 정규식을 통해 올바른 형식인지 검증해야 한다. 이를 통해 ;, &&, | 등의 명령 연결 문자를 원천적으로 차단할 수 있다.

2. 블랙리스트 방식의 필터링을 지양해야 한다. 블랙리스트는 특정 문자나 문자열만 차단하는 방식으로 구현되지만, 공격자는 다양한 우회 기법을 통해 이를 쉽게 회피할 수 있다. 실제 실습에서도 Medium과 High 단계에서 필터링이 적용되었음에도 우회 공격이 가능하였다. 따라서 차단 목록 방식보다는 허용 목록 방식이 보안적으로 더 안전하다.

3. 운영 체제 명령을 직접 실행하는 함수인 system(), exec(), shell_exec() 등의 사용을 최소화해야 한다. 이러한 함수는 사용자 입력이 그대로 명령어에 포함될 경우 매우 위험하다. 가능하다면 운영 체제 명령 대신 프로그래밍 언어나 라이브러리에서 제공하는 내부 API를 사용하는 것이 좋다. 예를 들어 네트워크 연결 확인이 필요하다면 외부 ping 명령어 대신 소켓 라이브러리를 활용할 수 있다.

4. 부득이하게 운영 체제 명령을 사용해야 하는 경우에는 입력값 이스케이프(Escaping) 처리를 적용해야 한다. 예를 들어 PHP에서는 escapeshellarg() 또는 escapeshellcmd() 함수를 사용하여 특수문자가 명령어로 해석되지 않도록 처리할 수 있다. 이를 통해 입력값이 단순 문자열로 인식되어 명령 삽입을 방지할 수 있다.

5. 서버 프로세스에 대해 최소 권한 원칙(Principle of Least Privilege) 을 적용해야 한다. 웹 서버나 애플리케이션이 root 권한으로 실행될 경우 Command Injection 성공 시 시스템 전체가 위험해질 수 있다. 따라서 일반 사용자 권한으로 실행하고, 중요 파일 접근 권한을 제한하여 피해 범위를 최소화해야 한다.

6. 웹 애플리케이션 방화벽(WAF) 을 도입하여 비정상적인 입력 패턴을 탐지하고 차단할 수 있다. 예를 들어 ';; cat /etc/passwd', '&& whoami', '| ls' 와 같은 공격 패턴을 사전에 식별하여 차단함으로써 추가적인 보안 계층을 제공할 수 있다.

7. 로그 모니터링 및 침입 탐지 시스템(IDS/IPS) 을 통해 비정상적인 명령 실행 시도를 지속적으로 감시해야 한다. 공격자는 여러 번 우회 기법을 시도하기 때문에, 로그 분석을 통해 이상 행위를 조기에 발견하고 대응하는 것이 중요하다.

# V. 애플리케이션 보안 솔루션 개선 방안 점검

## 가. 애플리케이션 현황에 따라 점검 체크리스트

| 점검 항목 | 점검 내용 | O/X |
|---|---|---|
| 웹 서버 운영 상태 | Apache HTTP Server, Nginx 정상 실행 여부 확인 | |
| 서비스 포트 점검 | HTTP(80), HTTPS(443), SSH(22) 등 주요 포트 개방 여부 확인 | |
| 데이터베이스 보안 | MySQL, MariaDB 외부 접근 제한 여부 확인 | |
| 계정 관리 | 관리자 계정 비밀번호 복잡도 및 주기적 변경 여부 확인 | |
| 원격 접속 보안 | OpenSSH root 직접 로그인 제한 여부 확인 | |
| 방화벽 정책 | iptables 또는 UFW 적용 여부 확인 | |
| 로그 관리 | 시스템 로그 및 인증 로그 정상 기록 여부 확인 | |
| SQL Injection 점검 | 입력값 검증 및 Prepared Statement 적용 여부 확인 | |
| XSS/CSRF 점검 | HTML 인코딩 및 CSRF Token 적용 여부 확인 | |
| IDS/IPS 운영 여부 | Snort, Suricata 운영 여부 확인 | |

## 나. 악의적인 공격 위험 파악 방법

1. **현재 운용 중인 정보시스템의 네트워크 구성 및 아키텍처 현황을 파악한다.**
   내·외부의 악의적인 공격은 정보시스템의 물리적인 접근이 허용되지 않는 한, 네트워크를 이용하므로 네트워크 구성 현황 파악은 중요하다. 네트워크 망 분리, DMZ 구성 등을 파악한다.
2. **네트워크 구성에 따라 외부의 공격으로부터 1차적으로 보호되고 있는 영역과 공격 위험에 노출된 영역을 식별한다.**
   방화벽, IDS/IPS, DMZ 등 보안 장비가 적용된 구간과 외부 인터넷에 직접 연결되어 공격에 노출될 수 있는 구간을 구분하는 것은 중요하다. 이를 통해 보호가 필요한 핵심 자산과 취약한 영역을 파악하고 우선적으로 보안 대책을 적용할 수 있다.
3. **포트 스캔, 보안 취약점 분석 도구를 사용하여 공격 위험에 노출된 취약점은 없는지 점검한다.**
   정보시스템에서 개방된 포트와 실행 중인 서비스는 공격자의 주요 진입 경로가 될 수 있으므로 정기적인 점검이 중요하다. 포트 스캔과 취약점 분석 도구를 활용하여 불필요하게 열려 있는 서비스와 알려진 취약점을 확인하고, 이를 통해 보안 설정 강화 및 위험 요소 제거가 가능하다.

## 다. 보안관련 법 및 규정에 따른 준거 사항

| 구분 | 주요 내용 | 법 적용 대상 |
|---|---|---|
| 개인정보 보호법 | 제24조(고유 식별 정보의 처리 제한) ③ 개인 정보 처리자가 제1항 각호에 따라 고유 식별 정보를 처리하는 경우에는 그 고유식별 정보가 분실, 도난, 유출, 변조 또는 훼손되지 아니하도록 대통령령으로 정하는 바에 따라 암호화 등 안전성 확보에 필요한 조치를 해야 한다.<br>제29조(안전조치 의무) 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 해야 한다. | 공공 기관, 법인, 단체 및 개인을 포함한 모든 개인정보 처리자 |
| 전자정부법 | 시행령 제69조(전자 문서의 보관, 유통 관련 보안 조치) ① 행정 기관의 장은 정보 통신망을 이용하여 전자 문서를 보관·유통할 때에는 법 제56조제3항에 따라 국가정보원장이 안전성을 확인한 다음 각 호의 보안 조치를 해야 한다.<br>국가정보원장이 개발하거나 안전성을 검증한 암호 장치와 정보보호 시스템의 도입·운용 | 중앙 부처, 자치 단체 등 공공 기관 |

# VI. 애플리케이션 보안 솔루션 운영

## 가. 운영 중인 애플리케이션 보안 솔루션 점검체크리스트

운영 중인 애플리케이션의 보안 솔루션을 점검하기 전에 현재 적용된 보안 정책과 취약점 현황을 확인해야 한다. 점검 체크리스트는 CVE(common vulnerabilities and exposures)와 같은 공개 취약점 정보를 참고하여 최신 보안 위협에 대응할 수 있도록 지속적으로 업데이트해야 한다.

| 점검 항목 | 점검 내용 | O/X |
|---|---|---|
| 보안 패치 적용 여부 | 운영 중인 애플리케이션 및 서버에 최신 보안 패치가 적용되어 있는지 확인 | |
| 알려진 취약점 확인 | CVE 기반으로 현재 사용 중인 서비스의 취약점 존재 여부 점검 | |
| 웹 방화벽(WAF) 정책 점검 | SQL Injection, XSS, CSRF 차단 정책이 정상 적용되어 있는지 확인 | |
| IDS/IPS 운영 상태 점검 | Snort 또는 Suricata 탐지 룰 정상 동작 여부 확인 | |
| 불필요 서비스 점검 | 사용하지 않는 애플리케이션 및 서비스가 실행 중인지 확인 후 비활성화 | |
| 포트 개방 상태 점검 | 불필요한 포트가 열려 있지 않은지 확인 | |
| 접근 제어 정책 점검 | 관리자 페이지, DB, SSH 접근 권한이 최소 권한 원칙으로 설정되어 있는지 확인 | |
| 로그 수집 및 분석 점검 | 시스템 및 애플리케이션 로그가 정상적으로 기록되고 있는지 확인 | |
| 계정 보안 점검 | 기본 계정 사용 여부, 비밀번호 복잡도 및 변경 주기 확인 | |
| 백업 및 복구 정책 점검 | 장애 및 공격 발생 시 데이터 복구를 위한 백업 정책 적용 여부 확인 | |

## 나. 점검 및 결과 값

| 점검 항목 | 점검 결과 | O/X |
|---|---|---|
| 보안 패치 적용 여부 | Ubuntu 서버에 최신 보안 패치가 적용되어 있었으며, 미적용 패치는 발견되지 않음 | O |
| 알려진 취약점 확인 | DVWA 환경에서 Command Injection 취약점이 확인되었으며 /etc/passwd 파일 노출 가능함을 확인함 | X |
| 웹 방화벽(WAF) 정책 점검 | SQL Injection, XSS, CSRF 차단 정책이 적용되어 있지 않아 공격 차단이 불가능한 상태임 | X |
| IDS/IPS 운영 상태 점검 | Snort 및 Suricata가 설치되어 있지 않아 침입 탐지 및 차단 기능이 동작하지 않음 | X |
| 불필요 서비스 점검 | 사용하지 않는 Telnet, FTP 서비스가 비활성화되어 있으며 불필요 프로세스가 발견되지 않음 | O |
| 포트 개방 상태 점검 | SMTP(25), DNS(53), HTTP(80) 외 불필요 포트는 개방되지 않은 상태로 확인됨 | O |
| 접근 제어 정책 점검 | SSH root 직접 로그인 제한 및 관리자 권한 최소화 설정이 적용되어 있음 | O |
| 로그 수집 및 분석 점검 | 시스템 로그와 Apache 로그가 정상적으로 기록되고 있으며 로그 누락은 발견되지 않음 | O |
| 계정 보안 점검 | 기본 계정 사용은 없으며 비밀번호 정책이 적용되어 복잡성 기준을 만족함 | O |
| 백업 및 복구 정책 점검 | 메일 서버 설정 및 DNS Zone 파일에 대한 정기 백업 정책이 설정되지 않음 | X |

점검 결과, 보안 패치 적용, 포트 관리, 접근 제어, 로그 관리는 정상적으로 이루어지고 있었으나, WAF 정책, IDS/IPS 운영, 백업 정책 부분은 미흡한 것으로 확인되었다. 특히 DVWA 실습 과정에서 Command Injection 취약점이 직접 확인되었기 때문에 웹 공격 방어 정책 강화가 필요하다. 향후 WAF 도입, IDS/IPS 활성화, 정기 백업 정책 수립을 통해 보안성을 강화해야 한다.

## 다. 점검 항목 이상 상황 발견 시 중요도별 조치 방법

**1. Command Injection 취약점**

중요도가 높은 항목으로 분류되며, 입력값 검증 미흡으로 인해 시스템 파일 접근이 가능하였으므로 즉시 조치가 필요하다. 이에 따라 사용자 입력값에 대해 화이트리스트 기반 검증을 적용하고, 특수문자 필터링 및 system(), exec()와 같은 위험 함수 사용을 제한하도록 개선할 수 있다.

**2. 웹 방화벽(WAF) 미적용 상태**

웹 공격(SQL Injection, XSS, CSRF 등)에 직접 노출될 가능성이 높아 중요도가 높은 항목으로 판단하였다. 이에 따라 WAF 정책을 적용하여 비정상적인 요청 패턴을 탐지하고 차단할 수 있도록 설정한다.

**3. IDS/IPS 미운영 상태**

공격 탐지 및 대응 능력 부족으로 이어질 수 있으므로 중간 이상의 중요도를 가진 항목으로 분류하였다. 이를 해결하기 위해 Snort 또는 Suricata와 같은 침입 탐지 시스템을 설치하고 탐지 규칙을 적용하여 비정상 트래픽을 실시간으로 감시할 수 있도록 조치한다.

**4. 백업 및 복구 정책 미설정 상태**

장애나 공격 발생 시 서비스 복구 지연 및 데이터 손실 가능성이 있어 중요도가 높은 항목으로 판단하였다. 이에 따라 메일 서버 설정 파일, DNS Zone 파일, 웹 애플리케이션 데이터에 대한 정기 백업 정책을 수립하고 주기적으로 복구 테스트를 수행하도록 설정한다.

# Ⅶ. 애플리케이션 보안 솔루션 업데이트 적용

점검 결과를 바탕으로 운영 중인 애플리케이션 보안 솔루션에 대한 업데이트를 적용한다. 먼저 시스템 패키지 및 보안 패치를 최신 상태로 유지하기 위해 Ubuntu 패키지 관리자를 이용하여 업데이트를 수행한다. 이를 통해 알려진 취약점(CVE)에 대한 보안 패치를 적용하고 시스템 안정성을 강화한다.

또한 웹 애플리케이션의 취약점 대응을 위해 입력값 검증 로직을 개선하고 Command Injection 취약점이 발생하지 않도록 화이트리스트 기반 필터링을 적용한다. 기존의 블랙리스트 방식은 우회 가능성이 확인되었기 때문에 허용된 입력 형식만 처리하도록 수정한다.

웹 공격에 대응하기 위해 웹 방화벽(WAF) 정책을 최신 공격 패턴에 맞게 업데이트한다. SQL Injection, XSS, CSRF와 같은 대표적인 웹 취약점 공격 패턴을 탐지 및 차단할 수 있도록 규칙을 추가한다.

침입 탐지 및 방지 기능 강화를 위해 IDS/IPS 솔루션의 최신 룰셋을 적용한다. Snort 또는 Suricata의 탐지 규칙을 업데이트하여 최신 악성 트래픽과 비정상 행위를 실시간으로 탐지할 수 있도록 구성한다.

마지막으로 로그 모니터링 및 백업 정책을 강화한다. 시스템 및 애플리케이션 로그를 주기적으로 점검하고, 메일 서버 설정 파일과 DNS Zone 파일, 웹 데이터에 대한 정기 백업을 수행하도록 설정한다. 이를 통해 장애 발생 시 빠른 복구가 가능하도록 보안 운영 체계를 보완한다.

이와 같은 보안 솔루션 업데이트 적용을 통해 운영 중인 애플리케이션의 취약점을 보완하고 최신 위협에 대응할 수 있는 보안 수준을 향상시킬 수 있다.